

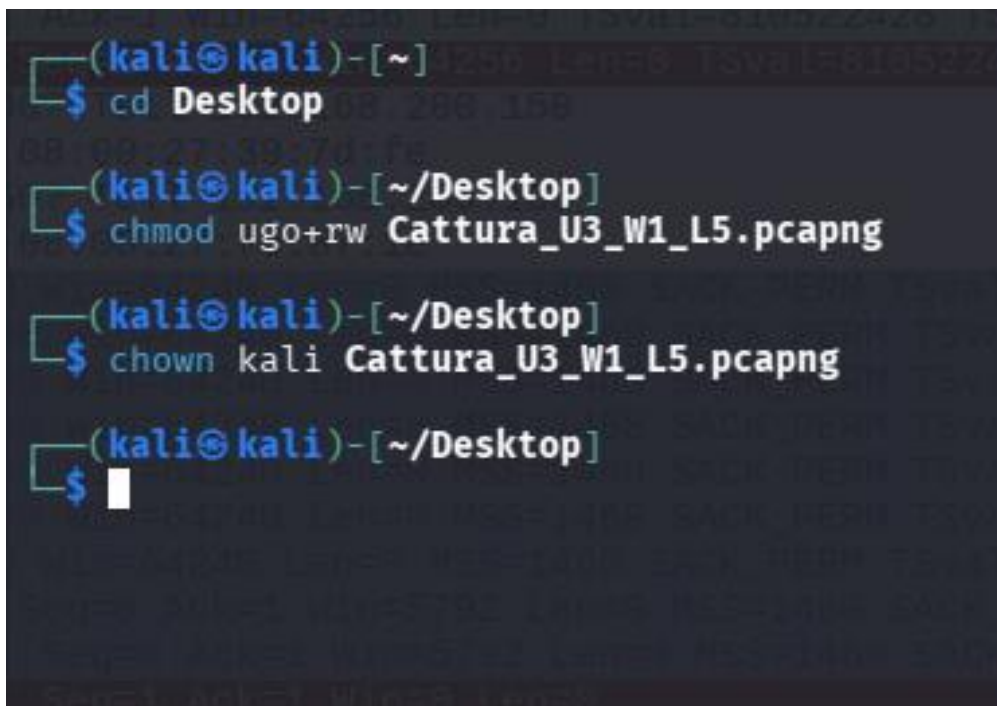
Analisi della Cattura di Rete: Threat Intelligence e IOC

1. Sintesi, Obiettivo e Preparazione dell'Ambiente

Il rapporto espone l'analisi tecnica di una cattura di traffico effettuata con Wireshark, finalizzata a simulare un'attività di Threat Intelligence. L'**obiettivo** didattico dell'attività è duplice: identificare gli indicatori di compromissione (IOC) all'interno di un flusso di rete e formulare un'ipotesi tecnica sul vettore di attacco utilizzato, definendo al contempo le strategie necessarie per mitigare l'impatto di simili minacce in futuro.

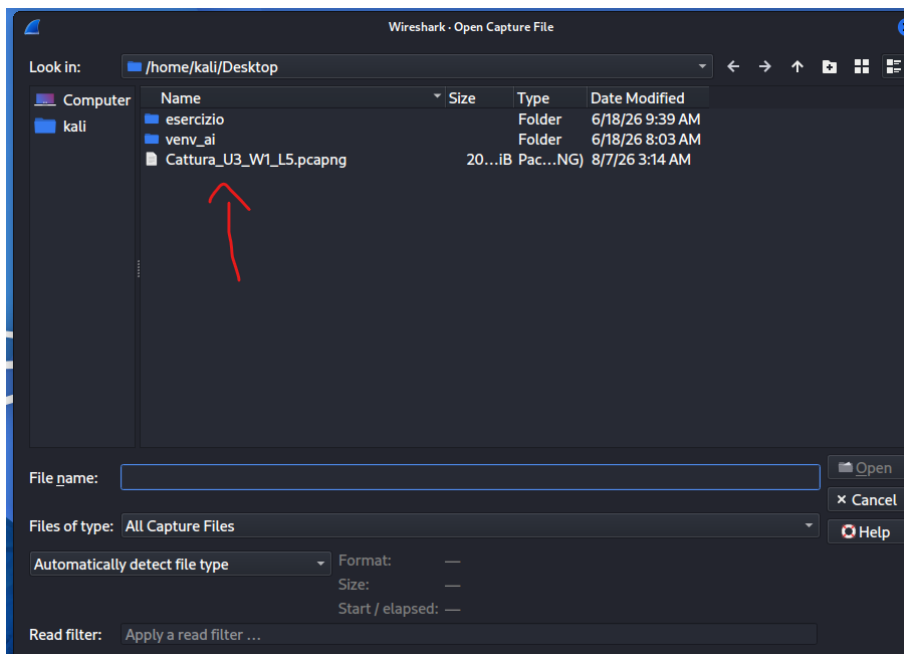
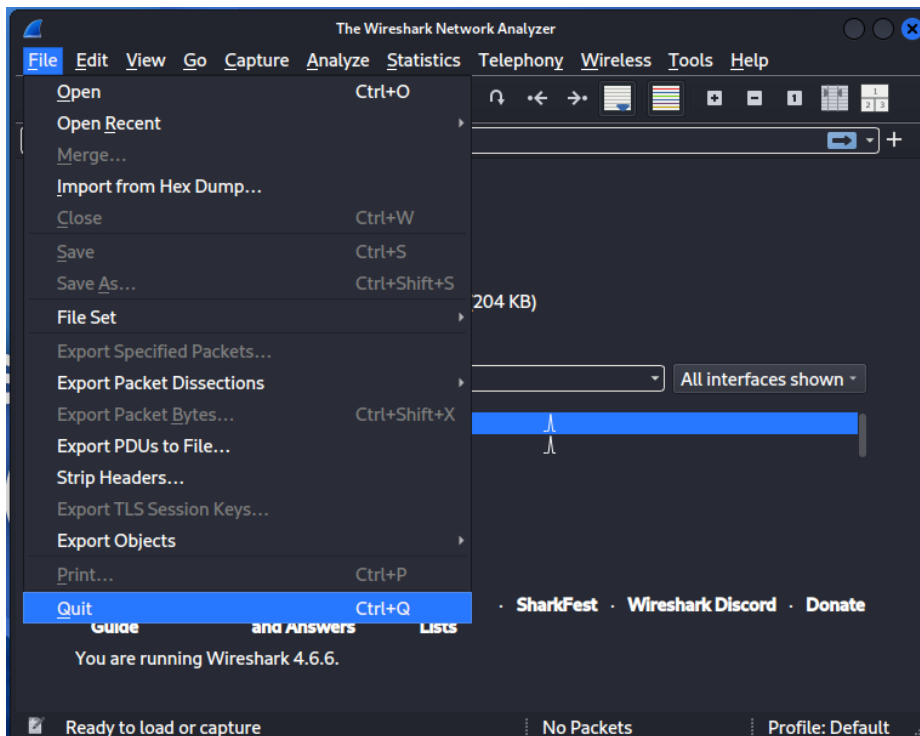
Prima di avviare l'analisi grafica su Wireshark, è stata eseguita una procedura preliminare direttamente da terminale Linux (Kali OS), visibile nella sequenza di comandi:

- ***cd Desktop***: Sposta la directory di lavoro corrente sul Desktop, ovvero il percorso in cui si trova il file di cattura.
- ***chmod ugo+rw Cattura_U3_W1_L5.pcapng***: Modifica i permessi del file pcapng concedendo i diritti di lettura e scrittura (*read and write*) a tutte le categorie di utenti (*ugo: user, group, others*), evitando così errori di accesso in fase di apertura.
- ***chown kali Cattura_U3_W1_L5.pcapng***: Assegna la proprietà del file all'utente attivo kali, garantendo il pieno controllo operativo sull'archivio della cattura di rete.



```
(kali㉿kali)-[~]  
$ cd Desktop  
(kali㉿kali)-[~/Desktop]  
$ chmod ugo+rw Cattura_U3_W1_L5.pcapng  
(kali㉿kali)-[~/Desktop]  
$ chown kali Cattura_U3_W1_L5.pcapng  
(kali㉿kali)-[~/Desktop]  
$
```

Succesivamente si è andati ad avviare il programma Wireshark, aprire il file ed iniziare l'analisi



2. Identificazione e Analisi degli IOC (Indicatori di Compromissione)

Gli **IOC** sono evidenze digitali che confermano una minaccia in corso o già avvenuta. Dall'analisi della cattura sono emersi i seguenti indicatori:

- **Attività di Scansione Massiccia (Port Scanning):** È stato osservato un flusso continuo di pacchetti TCP inviati con il flag **[SYN]** (che richiede l'apertura di una nuova connessione)

dall'indirizzo IP 192.168.200.150(macchina attaccante) verso l'indirizzo 192.168.200.100(macchina target).

- La costante risposta del target con flag **[RST, ACK]** (che indica il rifiuto della connessione) conferma che l'attaccante sta sondando sequenzialmente porte chiuse per identificare quali servizi siano effettivamente esposti.

No.	Time	Source	Destination	Protocol	Length	Info
79	36.777623140	192.168.200.150	192.168.200.100	TCP	60	78 -> 49780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
80	36.777645027	192.168.200.100	192.168.200.150	TCP	74	41874 -> 764 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
81	36.777680898	192.168.200.100	192.168.200.150	TCP	74	51506 -> 435 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
82	36.777690330	192.168.200.150	192.168.200.100	TCP	60	8090 -> 51505 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
83	36.777750696	192.168.200.150	192.168.200.100	TCP	60	962 -> 52428 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
84	36.777871245	192.168.200.150	192.168.200.100	TCP	60	764 -> 41874 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
85	36.777871293	192.168.200.100	192.168.200.150	TCP	60	435 -> 51506 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
86	36.77789298	192.168.200.100	192.168.200.150	TCP	60	3942 -> 445 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
87	36.777912717	192.168.200.100	192.168.200.150	TCP	60	46990 -> 139 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
88	36.77798759	192.168.200.100	192.168.200.150	TCP	60	68632 -> 25 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
89	36.778031265	192.168.200.100	192.168.200.150	TCP	60	37202 -> 53 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
90	36.77819716	192.168.200.150	192.168.200.100	TCP	74	51506 -> 145 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
91	36.778200161	192.168.200.100	192.168.200.150	TCP	74	48448 -> 806 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
92	36.778307830	192.168.200.100	192.168.200.150	TCP	74	54566 -> 221 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
93	36.778355345	192.168.200.150	192.168.200.100	TCP	60	243 -> 51505 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
94	36.778385946	192.168.200.150	192.168.200.100	TCP	60	806 -> 48448 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
95	36.778449494	192.168.200.150	192.168.200.100	TCP	60	221 -> 54566 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
96	36.778482791	192.168.200.100	192.168.200.150	TCP	74	42420 -> 1007 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
97	36.77851226	192.168.200.100	192.168.200.150	TCP	74	34646 -> 200 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
98	36.778614095	192.168.200.100	192.168.200.150	TCP	74	54202 -> 131 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
99	36.778663064	192.168.200.150	192.168.200.100	TCP	60	1007 -> 42420 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
100	36.778721080	192.168.200.100	192.168.200.150	TCP	60	200 -> 34646 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
101	36.778751510	192.168.200.150	192.168.200.100	TCP	74	51506 -> 132 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
102	36.778781327	192.168.200.100	192.168.200.150	TCP	74	51276 -> 677 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
103	36.778826294	192.168.200.150	192.168.200.100	TCP	60	131 -> 54202 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
104	36.778832493	192.168.200.100	192.168.200.150	TCP	60	392 -> 40318 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
105	36.778939327	192.168.200.150	192.168.200.100	TCP	60	677 -> 51276 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
106	36.778939427	192.168.200.150	192.168.200.100	TCP	74	47238 -> 64 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
107	36.778983151	192.168.200.100	192.168.200.150	TCP	60	64 -> 47238 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
108	36.779025210	192.168.200.150	192.168.200.100	TCP	60	40318 -> 132 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
109	36.779055243	192.168.200.100	192.168.200.150	TCP	74	55542 -> 807 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
110	36.779122299	192.168.200.150	192.168.200.100	TCP	60	84 -> 47238 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
111	36.779151684	192.168.200.100	192.168.200.150	TCP	74	40318 -> 132 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
112	36.779252084	192.168.200.150	192.168.200.100	TCP	60	807 -> 55542 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

- Identificazione di Host Vulnerabile:** Il traffico in chiaro di broadcast rivela l'annuncio di un sistema identificato esplicitamente come METASPLOITABLE. Si tratta di una macchina appositamente configurata con vulnerabilità note, utilizzata in ambito di test per dimostrare l'insicurezza di servizi obsoleti o non patchati.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential...
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23.764297888	192.168.200.100	192.168.200.150	TCP	74	53060 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 -> 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23.764777427	192.168.200.150	192.168.200.100	TCP	60	443 -> 53060 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.764835269	192.168.200.100	192.168.200.150	TCP	60	53060 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764898991	192.168.200.100	192.168.200.150	TCP	60	53060 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8	28.761629461	PCSSystemtec.f8:7d:1e	PCSSystemtec.39:7d:1e	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.761644619	PCSSystemtec.39:7d:1e	PCSSystemtec.f8:7d:1e	ARP	42	192.168.200.100 is at 08:00:27:39:7d:1e
10	28.774852257	PCSSystemtec.39:7d:1e	PCSSystemtec.f8:7d:1e	ARP	42	Who has 192.168.200.100? Tell 192.168.200.150
11	28.775230699	PCSSystemtec.f8:7d:1e	PCSSystemtec.39:7d:1e	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.774134445	192.168.200.100	192.168.200.150	TCP	74	41304 -> 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	56120 -> 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33078 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	58636 -> 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.774495627	192.168.200.100	192.168.200.150	TCP	74	52358 -> 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 -> 093 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 -> 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36.774685965	192.168.200.150	192.168.200.100	TCP	74	23 -> 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774686552	192.168.200.150	192.168.200.100	TCP	74	111 -> 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36.774835093	192.168.200.100	192.168.200.150	TCP	60	443 -> 53078 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774865737	192.168.200.150	192.168.200.100	TCP	60	554 -> 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774865776	192.168.200.150	192.168.200.100	TCP	60	135 -> 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.77490404	192.168.200.100	192.168.200.150	TCP	60	41304 -> 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774911972	192.168.200.100	192.168.200.150	TCP	60	56120 -> 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.775141104	192.168.200.150	192.168.200.100	TCP	60	993 -> 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 -> 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36.775174048	192.168.200.100	192.168.200.150	TCP	60	41182 -> 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.775337800	192.168.200.100	192.168.200.150	TCP	74	59174 -> 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36.775386694	192.168.200.100	192.168.200.150	TCP	74	55556 -> 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	53062 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36.775595090	192.168.200.150	192.168.200.100	TCP	60	135 -> 53078 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775619454	192.168.200.100	192.168.200.150	TCP	60	41304 -> 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.775652497	192.168.200.100	192.168.200.150	TCP	60	56120 -> 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

3. Ipotesi del Vettore di Attacco

- Port Scanning come fase di Ricognizione:** L'analisi del flusso di rete conferma che l'attaccante si trova attualmente nella fase di **ricognizione attiva (Reconnaissance)**, condotta mediante scansione automatizzata (Port Scanning). Attraverso l'invio sequenziale di pacchetti TCP [SYN] verso l'host target, l'attaccante mappa la superficie di attacco alla ricerca di servizi esposti e vulnerabili.

- L'analisi dei flag TCP osservati nei pacchetti catturati conferma l'utilizzo della tecnica di scansione **TCP Connect Scan**, attivata tramite il comando `nmap -sT`. Questa metodologia differisce dai metodi di scansione 'stealth' (half-open) poiché richiede che il sistema operativo dell'attaccante completi il *three-way handshake* standard per ogni porta sondata. La presenza costante di tentativi di connessione completi ([SYN] -> [SYN, ACK] / [RST, ACK]) conferma che l'attaccante ha interagito pienamente con lo stack TCP/IP del target, rendendo l'attività altamente visibile sia ai log di sistema del server (/var/log/auth.log o syslog) sia agli eventuali sistemi di rilevamento IDS/IPS presenti sulla rete. Il comando usato quindi è stato: `nmap -sT -p 1-1024 "IP_macchina_target"`

43	36.776233880	192.168.200.100	192.168.200.150	TCP	74 54220 - 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
44	36.776330010	192.168.200.100	192.168.200.150	TCP	74 34648 - 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
45	36.776385694	192.168.200.100	192.168.200.150	TCP	74 33842 - 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
46	36.776402580	192.168.200.100	192.168.200.150	TCP	74 48814 - 256 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
47	36.776451284	192.168.200.150	192.168.200.100	TCP	60 199 - 50684 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
48	36.776451357	192.168.200.150	192.168.200.100	TCP	60 995 - 54220 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
49	36.776476201	192.168.200.150	192.168.200.100	TCP	74 46999 - 133 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
50	36.776496360	192.168.200.100	192.168.200.150	TCP	74 33296 - 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
51	36.776512221	192.168.200.100	192.168.200.150	TCP	74 68632 - 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
52	36.776568690	192.168.200.100	192.168.200.150	TCP	74 49654 - 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
53	36.776671271	192.168.200.100	192.168.200.150	TCP	74 37282 - 53 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
54	36.776726715	192.168.200.100	192.168.200.150	TCP	74 54898 - 590 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
55	36.776813123	192.168.200.150	192.168.200.100	TCP	60 587 - 34648 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
56	36.776843423	192.168.200.150	192.168.200.100	TCP	74 51534 - 487 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
57	36.776894320	192.168.200.150	192.168.200.100	TCP	74 445 - 33842 [SYN, ACK] Seq=0 Ack=1 Win=0 Len=0
58	36.776904922	192.168.200.150	192.168.200.100	TCP	60 256 - 49814 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
59	36.776904961	192.168.200.150	192.168.200.100	TCP	74 139 - 46999 [SYN, ACK] Seq=0 Ack=1 Win=0 Len=0
60	36.776905094	192.168.200.150	192.168.200.100	TCP	60 143 - 33296 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
61	36.776905043	192.168.200.150	192.168.200.100	TCP	74 25 - 68632 [SYN, ACK] Seq=0 Ack=1 Win=0 Len=0
62	36.776905082	192.168.200.150	192.168.200.100	TCP	60 110 - 49654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
63	36.776905123	192.168.200.150	192.168.200.100	TCP	74 53 - 37282 [SYN, ACK] Seq=0 Ack=1 Win=0 Len=0
64	36.776905162	192.168.200.150	192.168.200.100	TCP	60 590 - 54898 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66 33842 - 445 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
66	36.776941020	192.168.200.100	192.168.200.150	TCP	66 46999 - 139 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
67	36.776962320	192.168.200.100	192.168.200.150	TCP	66 68632 - 25 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
68	36.776983878	192.168.200.100	192.168.200.150	TCP	66 37282 - 53 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
69	36.777118481	192.168.200.150	192.168.200.100	TCP	60 487 - 51534 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
70	36.777143814	192.168.200.100	192.168.200.150	TCP	74 56999 - 787 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
71	36.777186821	192.168.200.100	192.168.200.150	TCP	74 35638 - 436 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
72	36.777302991	192.168.200.100	192.168.200.150	TCP	74 34120 - 98 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
73	36.777337934	192.168.200.100	192.168.200.150	TCP	74 49780 - 78 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
74	36.777338632	192.168.200.150	192.168.200.100	TCP	60 787 - 56999 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
75	36.777339141	192.168.200.150	192.168.200.100	TCP	60 436 - 35638 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76	36.777473915	192.168.200.100	192.168.200.150	TCP	74 36138 - 590 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128

4. Azione Consigliata: Implementazione e Tuning di Sistemi IDS/IPS

1. Riduzione dell'impatto dell'attacco attuale

- **Intercettazione in tempo reale dell'anomalia:** Dalla cattura di rete analizzata emerge chiaramente una fase di ricognizione attiva (*port scanning*) condotta tramite l'invio massiccio e sequenziale di pacchetti TCP con flag [SYN] dall'indirizzo IP 192.168.200.150 verso il target 192.168.200.100. Un sistema IDS/IPS (*Intrusion Detection and Prevention System*) opportunamente calibrato riconosce questo pattern comportamentale anomalo non appena si manifesta sulla rete.
- **Risposta automatica e neutralizzazione:** A differenza di un semplice sistema di monitoraggio passivo, l'IPS agisce come contromisura immediata attivando una risposta di blocco dinamico (*drop/reject*) dell'indirizzo IP sospetto. Questo tronca all'istante la comunicazione tra l'attaccante e il server target, impedendo che la fase di scansione possa evolvere con successo in un attacco di esecuzione di codice remoto (RCE) o in un'effettiva violazione sistemica.
- **Isolamento dell'host scanner e quarantena del bersaglio:** Isolare e bloccare l'host che effettua la scansione a livello di firewall (verificando se l'attività è autorizzata, ad esempio

proveniente da 192.168.11.100). Inoltre, un sistema con il profilo di *Metasploitable* va rimosso dalla rete o isolato immediatamente in un ambiente di produzione reale.

- **Disattivazione dei servizi superflui:** Disattivare rigorosamente i servizi non necessari — in particolare Telnet, FTP e i vecchi *r-services* (porte 512, 513, 514) — che rappresentano la causa diretta di un'enorme superficie d'attacco esposta.

5. Prevenzione e mitigazione di simili attacchi futuri

- **Creazione di una barriera perimetrale proattiva:** L'adozione di un IPS tarato su regole comportamentali specifiche assicura una protezione continua H24. Qualsiasi host malevolo che in futuro dovesse tentare un'attività analoga di ricognizione o mappatura delle porte verrebbe intercettato e neutralizzato automaticamente prima ancora di poter interagire con i servizi interni.
- **Evoluzione della postura di sicurezza:** Sposta il paradigma difensivo da una gestione reattiva (basata sull'analisi post-mortem dei log) a una risposta proattiva e automatizzata, riducendo drasticamente il tempo di esposizione della rete e mitigando il rischio di errore umano durante le fasi critiche di un incidente.
- **Firewall in default-deny e segmentazione di rete:** Esporre esclusivamente le porte strettamente necessarie tramite una configurazione restrittiva.
- **Dismissione dei protocolli legacy insicuri:** Sostituire Telnet con SSH, rimuovere i servizi rsh, rlogin e rexec, e migrare da FTP a SFTP o FTPS.
- **Implementazione di IDS/IPS e rate-limiting:** Integrare sistemi come Snort o Suricata con regole di rilevamento delle scansioni, affiancati da limitazioni di tasso (*rate-limiting*) e fail2ban per contrastare gli attacchi a forza bruta.
- **Patch management e vulnerability scanning periodici:** Aggiornare regolarmente o eliminare definitivamente i servizi in ascolto non sicuri.
- **Logging e alerting avanzato:** Monitorare tempestivamente i pattern anomali come un alto volume di pacchetti [RST] in pochi secondi o connessioni multiple verso porte differenti dallo stesso indirizzo IP per individuare rapidamente tentativi di scansione.